

Tuần 7 — Security II — KMS + Secrets Manager/Parameter Store + Encryption → HẾT Domain 2

Domain: Domain 2 – Security (26%) · **Thời lượng:** ~11h (4 buổi) · **Vị trí:** Tuần 2/2
— KẾT THÚC Domain 2, có CHECKPOINT

Điều hướng:  Tuần 6 ·  Kế hoạch tổng · Tuần 8 

Mục tiêu tuần này

- **Quyết định được** trong 5 giây: mã hoá dữ liệu > 4 KB → dùng **envelope encryption** (không gọi **KMS** encrypt trực tiếp).
- **Tự tay** chạy **GenerateDataKey**, mã hoá/giải mã file local, và mô tả lại đúng luồng envelope encryption.
- **Phân biệt được** 3 loại key (AWS owned / AWS managed / customer managed CMK) và khi nào dùng loại nào.
- **Giải thích được** khác nhau **key policy vs grant vs IAM policy**, và bật automatic rotation cho CMK.
- **Chọn đúng** **Secrets Manager** vs **SSM Parameter Store** chỉ từ keyword đề (rotation tự động / free / config đơn giản).
- **Đọc được** secret + SecureString param từ **Lambda** mà KHÔNG hard-code credential.
- **Chốt Domain 2:** đạt **≥72%** ở MINI-MOCK Domain 1+2 (~30 câu) trước khi sang Tuần 8.

Nội dung học chi tiết

Buổi A — Lý thuyết (~3h)

1. **KMS** — nền tảng mã hoá (cực hay hỏi)

- **Symmetric vs Asymmetric:**

- **Symmetric** (mặc định, **AES-256**): 1 key dùng cả mã hoá + giải mã. Key **không bao giờ rời KMS** dưới dạng plaintext → mọi thao tác qua API. Đây là loại dùng cho gần như mọi tình huống để.
- **Asymmetric (RSA/ECC)**: cặp public/private. Dùng cho **sign/verify** hoặc **mã hoá phía client** bên ngoài AWS (nơi không gọi được API **KMS**).
- **Giới hạn encrypt trực tiếp = 4 KB**: API **Encrypt/Decrypt** chỉ nhận tối đa **4 KB** dữ liệu. Dữ liệu lớn hơn → **BẮT BUỘC** dùng envelope encryption.
- **Envelope encryption (luồng chuẩn)**:
 1. Gọi **GenerateDataKey** → nhận về **data key plaintext** + **data key đã mã hoá** (encrypted bằng CMK).
 2. Dùng data key plaintext mã hoá dữ liệu **local** (client-side).
 3. Lưu **kèm** data key đã mã hoá cạnh dữ liệu.
 4. **Xoá** data key plaintext khỏi bộ nhớ ngay.
 5. Khi cần giải mã: gọi **Decrypt** trên data key đã mã hoá để lấy lại plaintext key → giải mã dữ liệu local.

2. Loại key + alias + rotation

Loại key	Ai quản	Rotation	Tuỳ biến policy
AWS owned	AWS (ẩn, dùng chung nhiều account)	AWS lo	✗ không thấy
AWS managed (aws/<service>)	AWS tự tạo cho từng service	tự rotate hằng năm	✗ không sửa được
Customer managed (CMK)	Bạn	bật/tắt automatic rotation	✓ tự viết key policy

- **Lưu ý thuật ngữ**: (**CMK** = *Customer Master Key* — tên cũ; AWS nay gọi là **KMS key** / **customer managed key**).
- **Alias**: tên thân thiện (**alias/my-key**) trỏ tới key ID → đổi key sau lưng mà code không phải sửa.
- **Rotation**: CMK bật automatic rotation → xoay **mỗi năm (365 ngày)**; **KMS giữ lại backing key cũ** để vẫn giải mã được dữ liệu đã mã hoá trước đó; ngoài default 365 ngày còn đặt được **custom rotation period** và **on-demand rotation** (rotate ngay lập tức).

- **Multi-region key:** bản sao key với **cùng key material** ở nhiều region → dữ liệu mã hoá ở region A giải mã được ở region B (dùng cho DR / global table).

3. Phân quyền **KMS**: key policy vs grant vs IAM

- **Key policy** = resource-based policy **BẮT BUỘC** của MỖI key. Không có nó → không ai (kể cả root) dùng được key. Đây là chốt chặn cuối cùng.
- **Grant** = uỷ quyền **tạm thời, linh hoạt** (thường cho service/role dùng key trong thời gian ngắn, có thể thu hồi) — không cần sửa key policy.
- **IAM policy** = gắn trên user/role; **kết hợp** với key policy (key policy phải cho phép account/principal thì IAM mới có hiệu lực).
- **Điều kiện kms:ViaService:** giới hạn key chỉ được dùng **thông qua 1 service cụ thể** (vd chỉ `s3.<region>.amazonaws.com` mới gọi được key này) → siết phạm vi dùng.

4. Encryption at rest & in transit

- **At rest:**
 - **S3 SSE-KMS**: mã hoá object bằng CMK, có audit qua **CloudTrail**; ngoài ra còn **SSE-S3** (AWS quản key) và **SSE-C** (client cấp key).
 - **EBS**: bật encryption khi tạo volume → dữ liệu + snapshot mã hoá bằng **KMS**.
 - **DynamoDB & RDS**: encryption at rest bằng **KMS** (bật lúc tạo bảng/instance).
- **In transit**: dùng **TLS**. **ACM** (AWS Certificate Manager) **cấp & tự gia hạn** chứng chỉ TLS cho các dịch vụ tích hợp (**ALB/CloudFront/API Gateway**) → khỏi lo cert hết hạn.

Buổi B — Hands-on (~3.5h)

 **Lab cầm tay chỉ việc (từng bước + lệnh + code):** labs.md.

Lab 1 — Envelope encryption thủ công với **GenerateDataKey**

1. Tạo CMK (customer managed):

```
aws kms create-key --description "dva-lab-cmk"
aws kms create-alias --alias-name alias/dva-lab --target-key-id <key-id>
```

2. Sinh data key (envelope):

```
aws kms generate-data-key --key-id alias/dva-lab --key-spec AES_256 \
  --query Plaintext --output text | base64 --decode > datakey.plain
```

(Bản đã mã hoá lấy từ field **CiphertextBlob** — lưu lại để giải mã sau.)

3. Dùng data key **plaintext** mã hoá file local (vd bằng **openssl enc -aes-256-cbc**), rồi **xoá datakey.plain**.
4. Khi cần đọc: gọi **aws kms decrypt --ciphertext-blob fileb://datakey.encrypted** để lấy lại plaintext key → giải mã file. Đây chính là luồng envelope.

Lab 2 — Bật automatic rotation cho CMK

```
aws kms enable-key-rotation --key-id <key-id>
aws kms get-key-rotation-status --key-id <key-id>
```

- Xác nhận **KeyRotationEnabled: true** → key sẽ xoay mỗi 365 ngày, backing key cũ vẫn giữ để giải mã dữ liệu cũ.

Lab 3 — Lưu secret & param

1. **Secrets Manager** (bật rotation, tích hợp RDS):

```
aws secretsmanager create-secret --name prod/db/creds \
  --secret-string '{"username":"admin","password":"P@ss"}'
```

Trong console: bật **automatic rotation** → chọn Lambda rotation + database → tạo lịch xoay (vd 30 ngày). Quan sát staging labels **AWSCURRENT/AWSPENDING**.

2. **Parameter Store** SecureString (mã hoá bằng **KMS**):

```
aws ssm put-parameter --name /app/prod/db-password --type SecureString \
  --value "P@ss" --key-id alias/dva-lab
aws ssm get-parameter --name /app/prod/db-password --with-decryption
```

(**--with-decryption** mới trả plaintext; standard tier **miễn phí**.)

Lab 4 — Đọc secret/param từ **Lambda** (không hard-code)

1. Gắn **Lambda** execution role quyền `secretsmanager:GetSecretValue` (hoặc `ssm:GetParameter`) và `kms:Decrypt` trên key liên quan.
2. Trong code, gọi SDK lấy secret lúc runtime — **không** nhét password vào source.
3. Nếu dùng environment variable của **Lambda**: bật **encryption bằng KMS** cho env var; log ra kết quả xử lý nhưng **KHÔNG log** giá trị secret.

C Buổi C — Bổ sung (~2.5h)

Secrets Manager vs SSM Parameter Store — bảng quyết định sống còn:

Tiêu chí	Secrets Manager	SSM Parameter Store
Rotation tự động	✅ built-in bằng Lambda	❌ (không dựng sẵn)
Tích hợp DB	✅ sẵn RDS/Redshift/DocumentDB	❌
Kiểu lưu	secret JSON, có staging labels	String / StringList / SecureString
Mã hoá	luôn mã hoá (KMS)	chỉ SecureString mã hoá (KMS)
Phân cấp path + versioning	có versioning	hierarchical theo path + versioning
Cross-account	✅	hạn chế
Chi phí	TÍNH PHÍ (mỗi secret + số API call)	standard tier MIỄN PHÍ ; advanced tier trả phí (param > 4 KB, nhiều hơn, throughput cao)

- **Phản xạ chốt:** "tự động **rotate credential DB**" → **Secrets Manager**; "lưu **config / plaintext / secret đơn giản, miễn phí**" → **Parameter Store**.
- **Staging labels** (**Secrets Manager**): **AWSCURRENT** (đang dùng), **AWSPENDING** (bản mới trong lúc rotate), **AWSPREVIOUS** (bản cũ để rollback).

Quản lý dữ liệu nhạy cảm trong code (rất hay hỏi ở Domain 2):

- **KHÔNG hard-code** credential/API key trong source, config commit lên Git, hay AMI.
- Ứng dụng lấy quyền qua **IAM role** (**Lambda/EC2/ECS** task role), không dùng access key tĩnh.
- Secret đọc **lúc runtime** từ **Secrets Manager/Parameter Store**; env var chứa secret phải **mã hoá bằng KMS**.
- **Sanitize log**: không ghi PII / password / token ra **CloudWatch Logs**.

Đọc thêm: **KMS** FAQ (envelope encryption, key policy vs grant, rotation), **Secrets Manager** User Guide (rotation, staging labels), **Parameter Store** (SecureString, tier).

D Buổi D — Practice + Review (~2h)

 **Bộ câu hỏi luyện tập của tuần:** [questions.md](#) — đáp án & giải thích: [answers.md](#). (bằng tiếng Anh — văn phong đề thật để làm quen đề.)

- Làm bộ câu hỏi chủ đề **KMS** + encryption + **Secrets Manager/Parameter Store**.
- ★ **MINI-MOCK Domain 1+2 (~30 câu)** trộn toàn bộ Tuần 1→7. **Ghi số câu sai**, phân loại theo dịch vụ.
- **Spaced repetition**: ôn flashcard số liệu theo mốc **1 / 3 / 7 ngày** (4 KB, 365 ngày, các loại key rất dễ lẫn).
- Chỉ sang Tuần 8 khi mini-mock **≥72%**.

PHẢI NHỚ tuần này

Fact	Con số / Ghi nhớ
KMS encrypt trực tiếp	tối đa 4 KB ; lớn hơn → envelope encryption
GenerateDataKey trả về	data key plaintext + data key đã mã hoá
Luồng envelope	mã hoá local bằng plaintext key → lưu kèm key đã mã hoá → xoá plaintext key
Symmetric	mặc định, AES-256 , key không rời KMS
Asymmetric	RSA/ECC — sign/verify hoặc mã hoá client ngoài AWS
AWS managed key	aws/<service> , tự rotate hằng năm , không sửa policy

Fact	Con số / Ghi nhớ
Customer managed CMK	tự viết key policy, bật/tắt rotation
Automatic rotation	mỗi 365 ngày ; giữ backing key cũ để giải mã dữ liệu cũ
Key policy	resource-based policy BẮT BUỘC mỗi key
Grant	ủy quyền tạm thời, linh hoạt , có thể thu hồi
kms:ViaService	giới hạn key chỉ dùng qua 1 service cụ thể
Multi-region key	cùng key material ở nhiều region
ACM	cấp + tự gia hạn cert TLS cho ALB/CloudFront/API GW
Secrets Manager	rotation tự động (Lambda) , tích hợp RDS, tính phí
Parameter Store	SecureString (KMS), phân cấp path, standard tier miễn phí, không rotation

⚠ Bẫy đề hay gặp

- Thấy "mã hoá **1 MB / file lớn**" → chọn nhầm gọi **KMS Encrypt** trực tiếp → sai vì giới hạn **4 KB** → đúng là **envelope encryption** (**GenerateDataKey**).
- Thấy "xoay vòng **credential DB tự động**" → chọn **Parameter Store** là **sai** → **Parameter Store** không có rotation → đúng là **Secrets Manager**.
- Thấy "lưu config / secret đơn giản, **tiết kiệm chi phí**" → chọn **Secrets Manager** (tốn phí) → đúng ra **Parameter Store** standard **miễn phí**.
- Nhầm **key policy** với IAM policy → nhớ key policy là **resource-based, bắt buộc** trên từng key; thiếu nó thì IAM cũng vô dụng.
- Thấy "ủy quyền **tạm thời** cho service dùng key mà không sửa policy" → đúng là **grant**, không phải sửa key policy.
- Thấy "cần **sign/verify** hoặc mã hoá phía client ngoài AWS" → chọn symmetric là sai → dùng **asymmetric key**.
- Thấy "cert TLS **hết hạn**, phải tự gia hạn" → đừng tự mua/tự renew → dùng **ACM** (tự gia hạn cho service tích hợp).
- Env var **Lambda** chứa password để plaintext → sai → phải **mã hoá bằng KMS** và không log ra.



Phản xạ nhanh (keyword → đáp án)

Thấy từ khoá	Bật ngay
mã hoá dữ liệu > 4 KB / file lớn	envelope encryption (GenerateDataKey)
mã hoá ≤ 4 KB, gọi API trực tiếp	KMS Encrypt/Decrypt
tự động xoay credential DB	Secrets Manager (rotation Lambda)
lưu config / secret đơn giản, miễn phí	Parameter Store (standard)
SecureString, phân cấp theo path	Parameter Store
ủy quyền tạm thời dùng key, thu hồi được	grant
bắt buộc để bất kỳ ai dùng được key	key policy
giới hạn key chỉ dùng qua 1 service	kms:ViaService
sign/verify hoặc mã hoá client ngoài AWS	asymmetric KMS key
cùng key giải mã ở nhiều region (DR)	multi-region key
cert TLS tự gia hạn cho ALB/CloudFront	ACM
không hard-code credential trong code	IAM role + Secrets Manager/Parameter Store
xoay key nhưng vẫn giải mã dữ liệu cũ	automatic rotation (giữ backing key cũ)



Lab checklist

- ☐ Tạo CMK + alias, chạy **Generate-data-key**, mã hoá/giải mã file local (envelope).
- ☐ Bật automatic rotation cho CMK, kiểm tra **KeyRotationEnabled: true**.
- ☐ Tạo secret ở **Secrets Manager** và bật rotation, quan sát staging labels.

- ☐ Tạo **SecureString** param ở **Parameter Store**, đọc bằng **--with-decryption**.
- ☐ Đọc secret/param từ **Lambda** qua role (không hard-code), env var mã hoá **KMS**, không log secret.

Cổng tự kiểm tra (phải trả lời trôi chảy mới sang tuần sau)

- Mã hoá 1 MB dữ liệu → dùng **KMS** trực tiếp hay **envelope encryption**? **Đáp án gọn: envelope encryption** — **KMS** encrypt trực tiếp chỉ tối đa 4 KB; gọi **GenerateDataKey**, mã hoá local, lưu kèm data key đã mã hoá, xoá plaintext key.
- **Secrets Manager vs Parameter Store** — chọn khi nào? **Đáp án gọn: cần rotation tự động / tích hợp DB / cross-account** → **Secrets Manager**; cần config đơn giản, **SecureString**, miễn phí → **Parameter Store** (standard).
- Khác nhau **key policy vs grant**? **Đáp án gọn: key policy** = resource-based policy **bắt buộc** trên từng key (chốt chặn); **grant** = uỷ quyền **tạm thời, linh hoạt, thu hồi được** mà không sửa key policy.
- Muốn xoay vòng **credential DB** tự động → dùng gì? **Đáp án gọn: Secrets Manager** với **automatic rotation bằng Lambda** (tích hợp sẵn RDS).
- 3 loại **KMS key** khác nhau ra sao? **Đáp án gọn: AWS owned** (ẩn, dùng chung) / **AWS managed** (**aws/<service>**, tự rotate hằng năm, không sửa policy) / **customer managed CMK** (tự viết policy, bật/tắt rotation).
- ★ **CHECKPOINT Domain 2: đã đạt ≥72% ở MINI-MOCK Domain 1+2 (~30 câu)** chưa? Nếu chưa → **KHÔNG** sang Tuần 8, ôn lại câu sai trước.

Tài nguyên tuần này

 **Đã crawl sẵn tài liệu AWS vào **resources/**** — đọc offline được.

- AWS Docs: **AWS KMS Developer Guide** — symmetric vs asymmetric, envelope encryption, key policy vs grant, rotation, multi-region key, **ViaService**.
- AWS Docs: **AWS Secrets Manager User Guide** — automatic rotation, RDS integration, staging labels.
- AWS Docs: **AWS Systems Manager Parameter Store** — String/StringList/SecureString, hierarchies, standard vs advanced tier.
- AWS Docs: **AWS Certificate Manager (ACM)** — cấp & tự gia hạn cert TLS.

- AWS Docs: [S3](#) SSE-KMS, [EBS/RDS/DynamoDB](#) encryption at rest.
- FAQ: [AWS KMS](#) FAQs, [AWS Secrets Manager](#) FAQs.
- Khoá học: Stephane Maarek — mục [KMS/SSM Parameter Store/Secrets Manager](#) & encryption; Adrian Cantrill — KMS & encryption fundamentals.



Checklist hoàn thành Tuần 7

- ☐ Hoàn thành 4 buổi A/B/C/D
- ☐ Thuộc lòng bảng "PHẢI NHỚ" (4 KB, envelope, loại key, rotation 365 ngày)
- ☐ Phân biệt được [Secrets Manager](#) vs [Parameter Store](#) qua keyword
- ☐ Hoàn thành 5 lab (envelope, rotation, secret, SecureString, đọc từ Lambda)
- ☐ **Đạt $\geq 72\%$ MINI-MOCK Domain 1+2 (~30 câu) — CHECKPOINT**
- ☐ Vượt Cổng tự kiểm tra